LABORATORIO DI SICUREZZA INFORMATICA

Modulo Didattico: Analisi di Intestazioni, Typosquatting e Social Engineering

Obiettivo dell'Esercitazione: Analizzare le seguenti bozze di e-mail inviate dal mittente (**Xprofessor**) in lingua inglese verso gli indirizzi legati ad Elon Musk. Gli e-mail integrano tecniche di **Social Engineering (urgenza, scarsità, call-to-action visibili)** per valutare come la combinazione di dominio trappola e pressione psicologica incrementi il tasso di errore degli utenti.



Figura 1: Mappa concettuale delle identità di posta e dei domini associati ai casi di studio.

1. Destinatario: `Elusk@gmial.com`

RISCHIO ELEVATO / PRIORITÀ CRITICA (TYPOSQUATTING)

From: Xprofessor <professore@istituto.edu>
To: Elon Musk <Elusk@gmial.com>
Subject: URGENT & CRITICAL: Exclusive Keynote Invitation - Expires in 2 Hours
Text: Dear Mr. Musk, We have reserved the final keynote slot for you at the Global AI Educational Summit. Confirmation required within **2 hours**.

CONFIRM KEYNOTE SLOT IMMEDIATELY →

Best regards, Xprofessor

VETTORE DI ATTACCO / RISCHIO
Combinazione di `gmial.com` (typosquatting) con un senso di urgenza esteso e priorità massima (2h) e un pulsante CTA appariscente.

DOMANDA GUIDA PER GLI STUDENTI
In che modo l'urgenza artificiale spinge l'utente a ignorare l'errore nel dominio del destinatario (`gmial.com`)?

2. Destinatario: `elonM@emial.com`

RISCHIO ELEVATO / PRIORITÀ CRITICA (TYPOSQUATTING)

From: Xprofessor <professore@istituto.edu>
To: Elon Musk <elonM@emial.com>
Subject: IMMEDIATE ACTION REQUIRED: Legal NDA Grant Revocation in 60 Mins
Text: Dear Elon, Legal regulations require your digital signature within **60 minutes** to prevent immediate forfeiture of the grant.

SIGN NDA NOW OR FORFEIT RIGHTS

Sincerely, Xprofessor

VETTORE DI ATTACCO / RISCHIO
Fuga di informazioni riservate (NDA) verso il dominio malevolo `emial.com` accelerata dal timore della perdita imminente del

DOMANDA GUIDA PER GLI STUDENTI
Perché i cybercriminali inseriscono scadenze orarie brevi per ostacolare le verifiche sulla legittimità dell'indirizzo?

5. Destinatario: e@x.com

RISCHIO ELEVATO / PRIORITÀ CRITICA (EXECUTIVE PHISH TARGET)

From: Xprofessor <professore@istituto.edu>
To: Elon Musk <e@x.com>
Subject: CRITICAL: Educational API Suspension Notice (Immediate Action)
Text: Dear Elon, Our university lab API access for X platforms faces immediate shutdown within **1 hour** due to automated holds.

OVERRIDE API SUSPENSION NOW

Regards, Xprofessor

ANALISI CONTESTO
Urgenza tecnica ad alta priorità verso l'indirizzo monocarattere `e@x.com` con finta minaccia di sospensione servizi.

DOMANDA GUIDA PER GLI STUDENTI
Come reagiscono i gateway antispam istituzionali di fronte a link con testo imperativo diretti a executive della società?

6. Destinatario: elon@tesla.com

RISCHIO ELEVATO / PRIORITÀ CRITICA (TARGETED SPEAR-PHISH)

From: Xprofessor <professore@istituto.edu>
To: Elon Musk <elon@tesla.com>
Subject: URGENT: Autonomous Vehicle Challenge Slot Cancellation Imminent
Text: Dear Mr. Musk, Registration closes in **45 minutes**. The remaining Tesla mentorship slot will be reallocated if not confirmed.

LOCK TESLA MENTORSHIP SPOT

Sincerely, Xprofessor

ANALISI CONTESTO
Attacco spear-phishing mirato su `tesla.com` sfruttando il timore della perdita di visibilità competitiva e scadenze imminenti.

DOMANDA GUIDA PER GLI STUDENTI
Perché un messaggio inviato a `tesla.com` necessita di superare le verifiche SPF e DKIM del server `istituto.edu` del mittente?

7. Destinatario: elonmusk@spacex.com

RISCHIO ELEVATO / PRIORITÀ CRITICA (URGENT DOCUMENT DROP)

From: Xprofessor <professore@istituto.edu>
To: Elon Musk <elonmusk@spacex.com>
Subject: CRITICAL: Mission 2026 Telemetry Conflict - Action Required
Text: Dear Mr. Musk, A critical telemetry frequency collision has been detected. Immediate document sign-off is required within **30 minutes**.

RESOLVE FREQUENCY CONFLICT NOW

Respectfully, Xprofessor

ANALISI CONTESTO
Falso allarme operativo urgente inviato a `spacex.com` per forzare l'apertura di un link malevolo mediante pulsante d'azione rosso.

DOMANDA GUIDA PER GLI STUDENTI
Quali rischi informatici comporta l'abitudine di cliccare su link a documenti esterni in e-mail ad alta priorità?

8. Destinatario: elon@nasa.com

RISCHIO ELEVATO / PRIORITÀ CRITICA (FAKE INSTITUTIONAL TLD)

From: Xprofessor <professore@istituto.edu>
To: Elon Musk <elon@nasa.com>
Subject: IMMEDIATE: Joint NASA-SpaceX $5M Grant Revocation
Text: Dear Dott. Musk, The allocated joint research grant funds of $5,000,000 will be revoked if not claimed within **15 minutes**.

CLAIM $5M GRANT IMMEDIATELY

Best regards, Xprofessor

VETTORE DI ATTACCO / RISCHIO
Minaccia finanziaria a priorità critica e scadenza in 15 minuti su dominio illegittimo `nasa.com` anziché il TLD `nasa.gov`.

DOMANDA GUIDA PER GLI STUDENTI
Perché l'abbinamento tra urgenza finanziaria e un TLD commerciale improprio (`.com` vs `.gov`) è un segnale di allarme fondamentale?